

INFORME DE PENTESTING

Test de Intrusión — Entorno de Laboratorio

LAB: LEGACY-FTP-SERVER

Plataforma: WHOAMI-LABS.COM

Objetivo: 172.17.0.2

Tipo de prueba	Caja negra (Black Box) — perímetro de red
Dificultad	Fácil (1 punto)
Fecha de ejecución	05 de octubre de 2026
Clasificación	CONFIDENCIAL
Versión del informe	1.0

Aviso de confidencialidad

El presente documento contiene información sensible relativa a la seguridad del sistema objetivo y se clasifica como CONFIDENCIAL. La información aquí recogida se ha obtenido en un entorno de laboratorio controlado y autorizado (plataforma educativa WHOAMI-LABS.COM) con fines exclusivamente formativos. Queda prohibida la reproducción o aplicación de estas técnicas contra sistemas sobre los que no se disponga de autorización explícita por escrito. El acceso no autorizado a sistemas informáticos está tipificado como delito.

Resumen ejecutivo

Se ha realizado un test de intrusión de caja negra sobre la máquina LEGACY-FTP-SERVER (172.17.0.2) perteneciente a la plataforma de laboratorios WHOAMI-LABS.COM. El objetivo era evaluar la seguridad del perímetro expuesto y obtener la bandera (flag) que acredita el compromiso del sistema.

Durante la evaluación se logró comprometer la confidencialidad del sistema y obtener la bandera **CTF{FTP_Directory_Traversal_Success}**. El vector de ataque combinó una **fuga de credenciales en la aplicación web** con una **configuración insegura del servicio FTP** que permitía a un usuario anónimo navegar fuera de su directorio raíz y leer ficheros sensibles del sistema, incluido el contenido del directorio `/root`.

En total se han identificado **6 hallazgos**, de los cuales **1 es de severidad crítica**, **2 de severidad alta** y el resto de severidad media o baja. La combinación de debilidades evidencia una gestión deficiente de credenciales y una configuración por defecto/insegura de servicios heredados (legacy).

Resumen de hallazgos

ID	Hallazgo	Severidad	Categoría
F-01	Control de acceso roto en FTP (directory traversal al sistema de ficheros)	ALTA	Broken Access Control
F-02	Credenciales expuestas en texto plano en la web pública	ALTA	Information Disclosure
F-03	ProFTPD 1.3.5a vulnerable a ejecución remota de código (CVE-2015-3306)	CRÍTICA	Software desactualizado
F-04	Acceso FTP anónimo habilitado	MEDIA	Configuración insegura
F-05	Servidor Apache 2.4.18 desactualizado	MEDIA	Software desactualizado
F-06	Divulgación de información sensible (endpoint server-status, correo interno)	BAJA	Information Disclosure

1. Alcance y objetivos

El alcance del test se limitó exclusivamente al host indicado por la plataforma de laboratorio, sin extenderse a otros sistemas de la red.

- **Activo objetivo:** 172 . 17 . 0 . 2 (LEGACY-FTP-SERVER)
- **Servicios en alcance:** todos los puertos TCP expuestos
- **Tipo de autorización:** entorno de laboratorio educativo autorizado
- **Objetivo principal:** comprometer el sistema y obtener la ROOT flag en formato CTF{...}

2. Metodología

La evaluación siguió una metodología estructurada alineada con estándares de referencia del sector (PTES y OWASP), organizada en las siguientes fases:

- **Reconocimiento y escaneo:** identificación de puertos, servicios y versiones.
- **Enumeración:** descubrimiento de contenido web y análisis de los servicios identificados.
- **Análisis de vulnerabilidades:** correlación de versiones y configuraciones con debilidades conocidas.
- **Explotación:** aprovechamiento del vector de acceso para comprometer el sistema.
- **Post-explotación:** acceso a información sensible y obtención de la evidencia (flag).

Herramientas utilizadas

- **Nmap 7.99** — escaneo de puertos y detección de servicios/versiones.
- **Gobuster v3.8.2** — enumeración de directorios y ficheros web.
- **Navegador web** — inspección manual de la aplicación.
- **Cliente FTP** — interacción con el servicio ProFTPD.

3. Desarrollo técnico del ataque

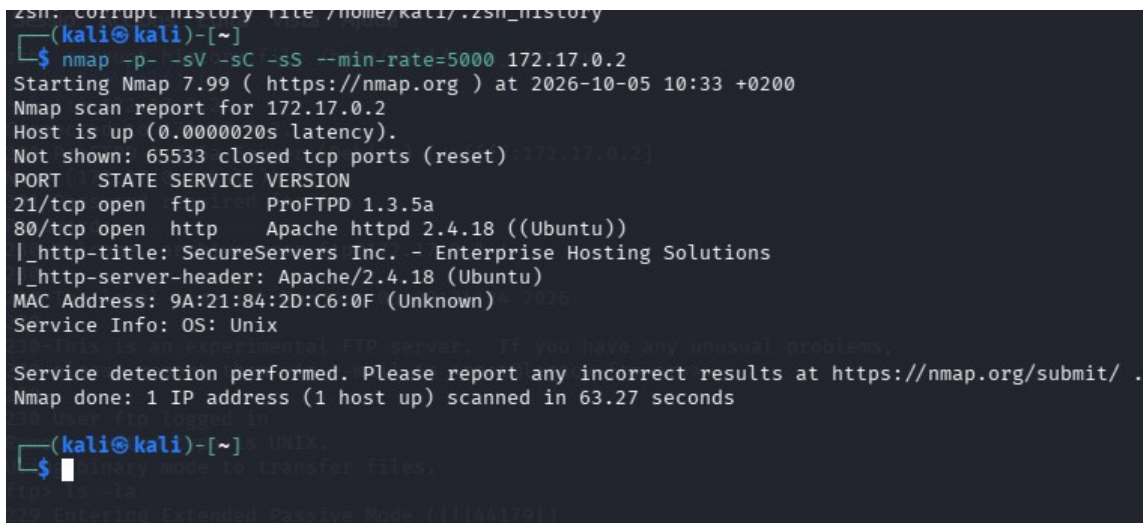
3.1. Fase 1 — Reconocimiento y escaneo de puertos

Se ejecutó un escaneo completo de puertos TCP con detección de versiones y scripts por defecto sobre el objetivo:

```
nmap -p- -sV -sC -sS --min-rate=5000 172.17.0.2
```

El escaneo reveló dos servicios expuestos, ambos basados en software con versiones antiguas:

- **Puerto 21/TCP — ProFTPD 1.3.5a** (servicio FTP)
- **Puerto 80/TCP — Apache httpd 2.4.18 (Ubuntu)** (servidor web «SecureServers Inc.»)



```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -p- -sV -sC -sS --min-rate=5000 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-05 10:33 +0200
Nmap scan report for 172.17.0.2
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5a
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_http-title: SecureServers Inc. - Enterprise Hosting Solutions
|_http-server-header: Apache/2.4.18 (Ubuntu)
MAC Address: 9A:21:84:2D:C6:0F (Unknown)
Service Info: OS: Unix

This is an experimental FTP server. If you have any unusual problems,
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.27 seconds

(kali@kali)-[~]
$
```

Figura 1. Resultado del escaneo Nmap: puertos 21 (ProFTPD 1.3.5a) y 80 (Apache 2.4.18) abiertos.

3.2. Fase 2 — Enumeración del servicio web

Sobre el servidor web (puerto 80) se realizó una enumeración de contenido con Gobuster, buscando ficheros y directorios no enlazados:

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x
py,txt,html,php -t 50
```

Se identificaron varias páginas accesibles (código 200), un directorio css (301) y el endpoint server-status (403), que, aunque protegido, confirma su existencia:

- `index.html`, `about.html`, `services.html` y `contact.html` — estado 200 (accesibles)
- `css/` — redirección 301
- `server-status` — estado 403 (presente pero restringido)

```
(kali@kali)-[~]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x py,txt,html,php -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://172.17.0.2
[+] Method:          GET
[+] Threads:         50
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8.2
[+] Extensions:      txt,html,php,py
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

.hta.txt                (Status: 403) [Size: 275]
.htpasswd.txt           (Status: 403) [Size: 275]
.htpasswd.py            (Status: 403) [Size: 275]
.htaccess.php           (Status: 403) [Size: 275]
.htpasswd.php           (Status: 403) [Size: 275]
.htaccess               (Status: 403) [Size: 275]
.htaccess.txt           (Status: 403) [Size: 275]
.htaccess.html          (Status: 403) [Size: 275]
.htaccess.py            (Status: 403) [Size: 275]
.hta.py                 (Status: 403) [Size: 275]
.hta.html               (Status: 403) [Size: 275]
.hta                    (Status: 403) [Size: 275]
.hta.php                (Status: 403) [Size: 275]
.htpasswd               (Status: 403) [Size: 275]
.htpasswd.html          (Status: 403) [Size: 275]
about.html              (Status: 200) [Size: 290]
contact.html            (Status: 200) [Size: 279]
css                     (Status: 301) [Size: 306] [→ http://172.17.0.2/css/]
index.html              (Status: 200) [Size: 1678]
index.html              (Status: 200) [Size: 1678]
server-status            (Status: 403) [Size: 275]
services.html           (Status: 200) [Size: 293]
Progress: 23065 / 23065 (100.00%)
```

Figura 2. Enumeración web con Gobuster. Destacan las páginas HTML accesibles y el endpoint server-status.

3.3. Fase 3 — Fuga de credenciales en la aplicación web

La inspección manual de la página `contact.html` reveló una grave fuga de información: la propia web mostraba, en texto plano, un correo de contacto y, lo más crítico, **credenciales de acceso al servicio FTP**.

```
Email: admin@legacyhost.com
FTP: ftp / ftp123
```

Esto expone directamente el usuario `ftp` y la contraseña `ftp123`, además de indicar implícitamente que el servicio FTP es un punto de entrada previsto. Publicar credenciales en una página accesible sin autenticación constituye una debilidad de alto impacto.

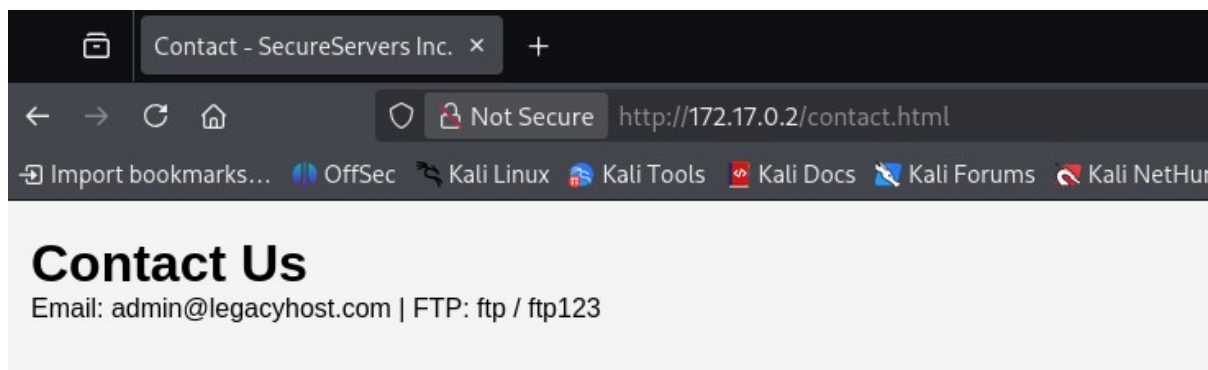


Figura 3. La página `contact.html` expone públicamente las credenciales del servicio FTP (`ftp / ftp123`).

3.4. Fase 4 — Explotación del servicio FTP y acceso a datos sensibles

Con la información recopilada se accedió al servicio FTP. El servidor permitió el inicio de sesión del usuario `ftp` (acceso de tipo anónimo/archive, confirmado por el banner «*archive user ftp@...*» y el mensaje `230 User ftp logged in`).

```
ftp 172.17.0.2
```

El directorio inicial era `/srv/ftp`. La debilidad crítica se evidenció al comprobar que el usuario **no estaba confinado («enjaulado»)** en su directorio raíz: fue posible cambiar de directorio hacia rutas arbitrarias del sistema de ficheros, incluido el directorio privado del superusuario:

```
ftp> cd /root
250 CWD command successful
ftp> ls
-rw-r--r-- 1 root root 37 ... flag.txt
ftp> more flag.txt
CTF{FTP_Directory_Traversal_Success}
```

Mediante esta navegación fuera del directorio permitido (directory traversal por control de acceso roto) se leyó el fichero `flag.txt` ubicado en `/root`, obteniendo la bandera que acredita el compromiso del sistema:

FLAG: CTF{FTP_Directory_Traversal_Success}

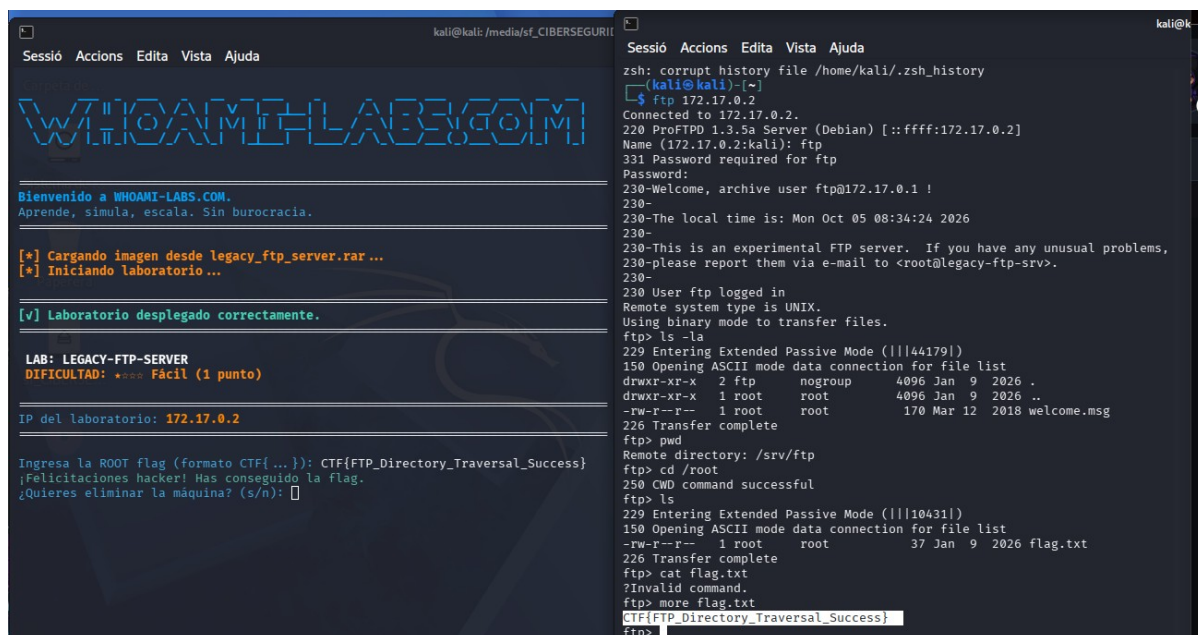


Figura 4. Sesión FTP: acceso anónimo, navegación a `/root` y lectura de `flag.txt`. A la izquierda, panel del laboratorio confirmando la flag.

4. Hallazgos detallados

F-03 — ProFTPD 1.3.5a vulnerable a RCE (CVE-2015-3306)

Severidad	CRÍTICA · CVSS 3.1: 9.8 (Crítica)
Clasificación	CWE-264 / Software desactualizado con vulnerabilidad conocida

Descripción

El servicio FTP ejecuta ProFTPD 1.3.5a. Esta versión incorpora el módulo `mod_copy`, afectado por la vulnerabilidad CVE-2015-3306, que permite a un atacante no autenticado copiar ficheros arbitrarios mediante los comandos `SITE CPFR` y `SITE CPTO`, pudiendo derivar en la ejecución remota de código (RCE) y el compromiso total del servidor.

Impacto

Un atacante podría tomar control completo del sistema de forma remota sin credenciales, comprometiendo confidencialidad, integridad y disponibilidad. Aunque el compromiso de este laboratorio se logró por otra vía, esta vulnerabilidad representa el riesgo más grave del sistema.

Recomendaciones

- Actualizar ProFTPD a la última versión estable soportada por el fabricante.
- Si no es posible actualizar de inmediato, deshabilitar el módulo `mod_copy` en la configuración.
- Evaluar la sustitución de FTP por alternativas cifradas (SFTP/FTPS).

F-01 — Control de acceso roto en FTP (acceso al sistema de ficheros)

Severidad	ALTA · CVSS 3.1: 7.5 (Alta)
Clasificación	CWE-22 / Broken Access Control (OWASP A01)

Descripción

El usuario FTP no está confinado a su directorio raíz (`/srv/ftp`). Es posible navegar hacia rutas arbitrarias del sistema, como `/root`, y leer ficheros sensibles pertenecientes a otros usuarios, incluido el superusuario. Esto fue el vector que permitió obtener la flag.

Impacto

Exposición de información confidencial de todo el sistema a cualquier usuario capaz de autenticarse (o conectarse de forma anónima) al FTP. Permite el reconocimiento interno del servidor y la lectura de credenciales, claves o datos privados.

Recomendaciones

- Configurar `DefaultRoot ~` en ProFTPD para «enjaular» (`chroot`) a cada usuario en su directorio.
- Aplicar el principio de mínimo privilegio sobre los permisos del sistema de ficheros.
- Revisar que ninguna cuenta de servicio tenga acceso de lectura a `/root` u otros directorios sensibles.

F-02 — Credenciales expuestas en la web pública

Severidad	ALTA · CVSS 3.1: 7.5 (Alta)
-----------	-----------------------------

Clasificación

CWE-200 / CWE-798 — Information Disclosure / Credenciales embebidas

Descripción

La página `contact.html`, accesible sin autenticación, muestra en texto plano las credenciales del servicio FTP (usuario «ftp», contraseña «ftp123») junto con un correo de contacto interno.

Impacto

Cualquier visitante obtiene credenciales válidas de acceso, reduciendo drásticamente el esfuerzo de un atacante y encadenándose con otras debilidades para comprometer el sistema.

Recomendaciones

- Eliminar de inmediato cualquier credencial del contenido web publicado.
- Rotar la contraseña expuesta y aplicar una política de contraseñas robustas.
- Revisar el resto del sitio y el control de versiones en busca de secretos filtrados.

F-04 — Acceso FTP anónimo habilitado**Severidad****MEDIA** · CVSS 3.1: 5.3 (Media)**Clasificación**

CWE-287 — Configuración de autenticación insegura

Descripción

El servidor FTP permite el inicio de sesión del usuario anónimo/«archive» (ftp) sin una autenticación robusta, ampliando innecesariamente la superficie de ataque.

Impacto

Facilita el acceso inicial de cualquier atacante sin necesidad de credenciales legítimas, especialmente peligroso al combinarse con el control de acceso roto (F-01).

Recomendaciones

- Deshabilitar el acceso anónimo salvo que sea estrictamente necesario.
- Si se requiere, restringirlo a un directorio aislado y de solo lectura.
- Registrar y monitorizar las conexiones al servicio.

F-05 — Servidor Apache 2.4.18 desactualizado**Severidad****MEDIA** · CVSS 3.1: 5.0 (Media)**Clasificación**

Software desactualizado con vulnerabilidades conocidas

Descripción

El servidor web ejecuta Apache httpd 2.4.18 (Ubuntu), una versión antigua con numerosas vulnerabilidades publicadas a lo largo de los años.

Impacto

Aumenta la probabilidad de explotación de fallos conocidos en el servidor web y facilita el fingerprinting del sistema por parte de un atacante.

Recomendaciones

- Actualizar Apache a una versión soportada y aplicar parches de seguridad periódicamente.
- Ocultar la versión del servidor mediante la directiva ServerTokens Prod.

F-06 — Divulgación de información sensible

Severidad	BAJA · CVSS 3.1: 3.1 (Baja)
Clasificación	CWE-200 — Information Disclosure

Descripción

Se detecta la presencia del endpoint server-status (aunque protegido con 403) y la exposición de un correo interno (admin@legacyhost.com). Estos elementos aportan información útil para un atacante durante la fase de reconocimiento.

Impacto

Facilita el perfilado de la infraestructura y posibles ataques de ingeniería social o enumeración de usuarios.

Recomendaciones

- Deshabilitar mod_status o restringirlo estrictamente a redes de administración.
- Evitar exponer correos y datos internos en contenido público.

5. Conclusiones

El sistema LEGACY-FTP-SERVER presenta un nivel de seguridad bajo. El compromiso se consiguió sin necesidad de explotar vulnerabilidades complejas: bastó con encadenar una fuga de credenciales en la web con una configuración insegura del servicio FTP que no confinaba al usuario en su directorio.

El riesgo global se considera ALTO. Además del vector utilizado, el sistema expone software heredado con vulnerabilidades críticas conocidas (ProFTPD 1.3.5a, CVE-2015-3306) que permitirían un compromiso aún más directo y severo.

El ejercicio evidencia cómo debilidades individualmente «menores» (credenciales publicadas, acceso anónimo, falta de chroot) se combinan para producir un compromiso total de la confidencialidad del sistema.

6. Recomendaciones prioritarias

- **1. Actualizar ProFTPD y Apache** a versiones soportadas y aplicar parches de seguridad.
- **2. Confinar (chroot) a los usuarios FTP** mediante DefaultRoot y revisar permisos del sistema de ficheros.
- **3. Eliminar y rotar las credenciales expuestas** en la web; implantar gestión segura de secretos.
- **4. Deshabilitar el acceso FTP anónimo** y migrar a protocolos cifrados (SFTP/FTPS).
- **5. Reducir la superficie de información expuesta** (server-status, versiones, correos internos).
- **6. Implantar monitorización y registro** de accesos a los servicios perimetrales.

7. Anexo — Evidencias

Las capturas de pantalla incluidas a lo largo del informe (Figuras 1 a 4) constituyen la evidencia del proceso de intrusión: escaneo de puertos (Fig. 1), enumeración web (Fig. 2), fuga de credenciales (Fig. 3) y explotación del FTP con obtención de la flag (Fig. 4).